



certacito.ai

A4: Prototype Presentation

Governed. Auditable. Transparent.

Group 28 · CSIT321 Capstone Project · University of Wollongong · 2026

Nico · Daniel · Sai · Peter · Allan · Roland

Industry sponsor: Anthony Autore, AI Revolution 4 Technologies · Academic supervisor: Dr John Le

AI agents act on their own. Who checks their work?

Autonomous agents read databases, call APIs, write files and send emails without a human in the loop. Certacito.ai is the control layer that intercepts every one of those actions **before it executes**, enforces policy, and keeps the evidence.

Where we were at A3

Eight high-fidelity Figma screens, requirements locked with the sponsor, design approved by sponsor and supervisor.

What A4 shows

The same screens as a working system: live interception, policy decisions, human approvals and a tamper-evident audit trail - running end-to-end.

Today

Methodology check-in → system & interface design decisions → working prototype demo → progress vs plan → what's next.

10/11

FUNCTIONAL REQUIREMENTS
IMPLEMENTED

28

API ENDPOINTS LIVE

44

AUTOMATED TESTS PASSING

70k+

DECISIONS IN THE AUDIT
CHAIN

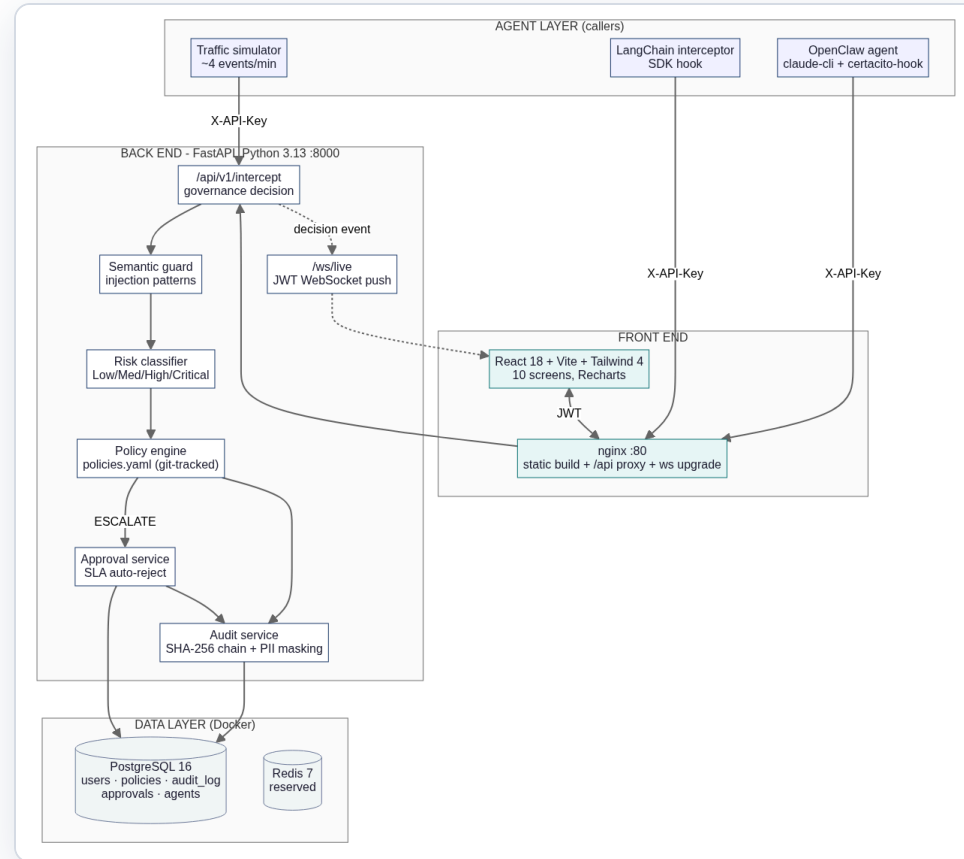
Agile Scrum + UCD, now in delivery mode

- **Same two methodologies as A1-A3:** Scrum governs how we build, User-Centred Design governs what we build. Fortnightly sponsor reviews continue.
- **What changed after A3:** per supervisor direction we froze the MVP scope - one primary use case (healthcare GP-office agent), the minimum governance loop, minimum screen set. Everything else deferred.
- **Accountability areas:** each member owns a visible slice (coordination, backend, frontend, integration & testing, documentation, interface) - matching the supervisor's assignment.
- **Definition of done tightened:** a story is done when it works against the live API with tests - not when the screen renders with mock data.

Sprint	Focus	Evidence
S1	Interception + policy engine + audit chain	git history, tests
S2	Approval queue, dashboard, WebSocket	commits 9497b1c... 95c5d12
S3	RBAC hardening, agent API keys, CI	commit a1100c1, 6 RBAC tests
S4 (this)	Live-data UI completion, chain repair, A4 docs	this build + docs/

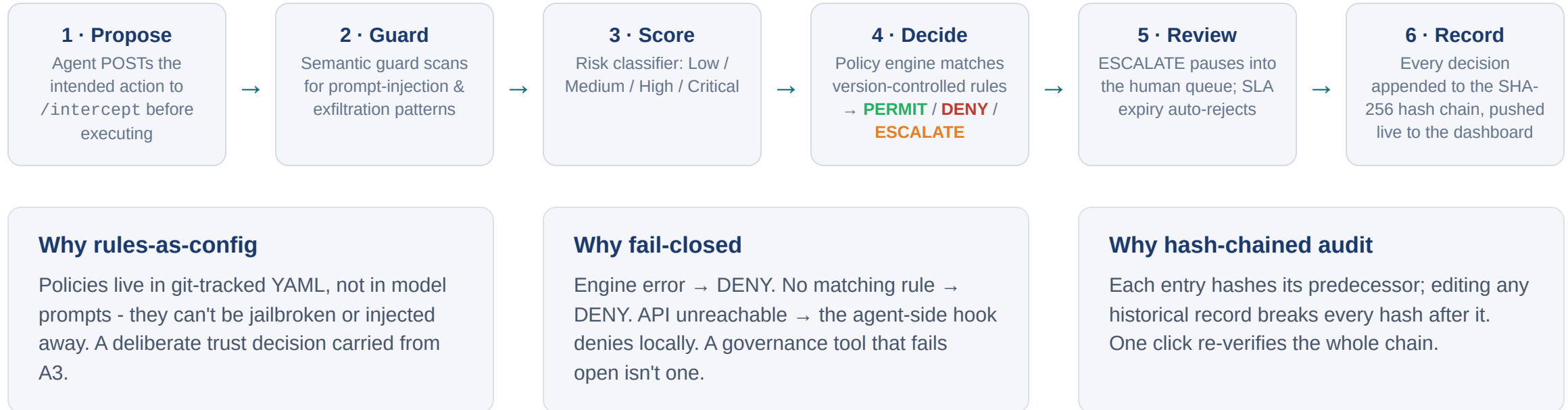
MoSCoW priorities unchanged since the Week 7 sponsor lock-in.

Architecture: four layers, fail-closed



Full detail in docs/architecture.md - React/Vite front end · FastAPI decision pipeline · PostgreSQL + Redis · agent callers over X-API-Key.

The governance loop, end to end



Requirements implemented to date

ID	Requirement (A2 baseline)	Status	Where a marker can verify
FR-01	Pre-execution interception, fail-closed	DONE	POST /api/v1/intercept
FR-02	Deterministic policy engine, rules in config	DONE*	backend/policies.yaml
FR-03	Immutable SHA-256 chained audit log	DONE	Verify chain button · /audit/verify
FR-04	RBAC at the API layer (3 roles)	DONE	RBAC regression tests
FR-05	Human approval queue + SLA auto-reject	DONE*	Approval Queue screen
FR-06	Real-time dashboard (<2s)	DONE	WebSocket live feed
FR-07	Secure Azure deployment	DONE	Live on an Azure VM, CI green on every push
FR-08	Semantic guardrails	DONE	/guardrails/check
FR-09	Risk classification engine	DONE	/risk/classify
FR-10	Policy rule library (5+ pre-built)	EXCEEDS	10 rules w/ regulatory tags
FR-11	Group 2 integration demo	BLOCKED	Healthcare demo stands in; awaiting their API contract

* documented limitations: simplified condition matcher (FR-02), lazy SLA evaluation (FR-05) - both in the RTM with the production plan.

From A3 Figma to A4 product - what changed and why

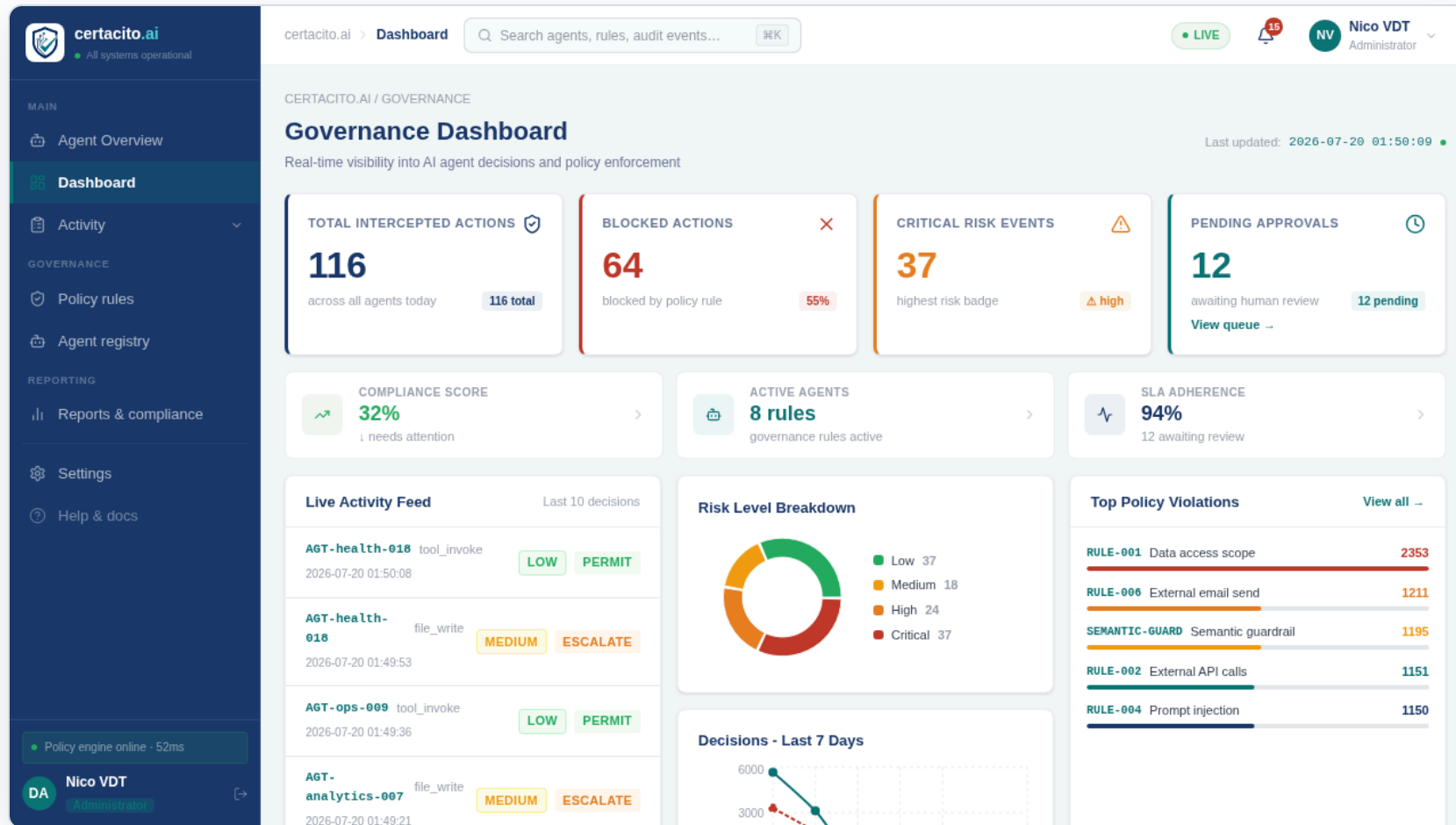
Change since A3	Why
Azure AD sign-in → local JWT login (SSO placeholder kept)	Azure not provisioned yet; same role-gated behaviour, swap isolated in one module
Static mock data → every panel driven by the live API + WebSocket push	A3 had to look real - A4 has to be real
Audit export modal → direct CSV/PDF export + one-click Verify chain	Surfaces the tamper-evidence story in one demo click
New public landing page	Exhibition visitors need the story before the console
Inter/JetBrains Mono → system font stack	Licensing-free, renders identically on any marker machine

What didn't change

- The A3 colour system - one job per colour
- Persistent sidebar + breadcrumb navigation
- Unified risk/outcome badge language
- WCAG 2.1 AA - risk never colour-only
- Both persona journeys (Compliance / DevSecOps)

Full change log with rationale: <docs/interface-design.md>

Governance Dashboard - live



Real decisions from the traffic simulator and the OpenClaw agent. New events appear via WebSocket push in under a second.

Audit log - tamper-evident evidence

The screenshot displays the 'Agent Decision Audit Log' interface. The left sidebar contains navigation links: MAIN (Agent Overview, Dashboard), Activity (Audit log, Approval queue), GOVERNANCE (Policy rules, Agent registry), and REPORTING (Reports & compliance, Settings, Help & docs). The top header shows 'certacito.ai' with 'All systems operational', a search bar, a 'LIVE' status, and a user profile 'Nico VDT Administrator'. The main content area is titled 'Agent Decision Audit Log' and includes a description: 'Review policy decisions, masked payloads, chain hashes and human escalation history.' It features four summary cards: 'TOTAL EVENTS 100 within current filtered view', 'DENIED 56 blocked by policy rule', 'ESCALATED 12 sent for human review', and 'CRITICAL RISK 32 highest risk badge'. Below these is a search bar and filter controls for risk levels, outcomes, and action types. A table lists audit events with columns for timestamp, agent ID, action type, matched policy rule, risk level, and outcome. The selected event is expanded to show a 'Full decision record' (Audit event ID: AUC-CDFDB236, Matched rule ID: RULE-008, Regulatory alignment: Internal Policy, Policy decision: PERMIT), a 'SHA-256 chain hash' (760f532e6483ceb45dbac36c7ea24d24b7bdf7bfa3f7572fcc810dcfc4392b0), and a 'Decision trail' (Policy engine matched RULE-008 - Matched RULE-008: Database schema read permit, Step 1: 2026-07-20 01:50:22, Decision PERMIT applied automatically, no human review required, Step 2: 2026-07-20 01:50:22). A 'Payload has been masked before display to protect personal and secret data.' message is also visible.

certacito.ai > Audit Log

certacito.ai All systems operational LIVE Nico VDT Administrator

CERTACITO.AI / ACTIVITY / AUDIT LOG

Agent Decision Audit Log

Review policy decisions, masked payloads, chain hashes and human escalation history.

✓ Hash chain intact - 1000 entries verified against their SHA-256 chain

TOTAL EVENTS
100
within current filtered view

DENIED
56
blocked by policy rule

ESCALATED
12
sent for human review

CRITICAL RISK
32
highest risk badge

TIMESTAMP	AGENT ID	ACTION TYPE	MATCHED POLICY RULE	RISK LEVEL	OUTCOME
2026-07-20 01:50:22	AGT-support-031	db_read	RULE-008 Matched RULE-008: Database schema read permit	LOW	PERMIT

Full decision record

Audit event ID: AUC-CDFDB236
Matched rule ID: RULE-008
Regulatory alignment: Internal Policy
Policy decision: **PERMIT**

SHA-256 chain hash

760f532e6483ceb45dbac36c7ea24d24b7bdf7bfa3f7572fcc810dcfc4392b0
prev: 0b35d1af479cfb2d312c0d675b51937c1afdc4ff023c7d251fc11fa58d025837

Decision trail

✓ Policy engine matched RULE-008 - Matched RULE-008: Database schema read permit
Step 1 · 2026-07-20 01:50:22
✓ Decision PERMIT applied automatically, no human review required
Step 2 · 2026-07-20 01:50:22

table: appointments
filter: today
Payload has been masked before display to protect personal and secret data.

Expanded decision record: PII-masked payload, this entry's SHA-256 chain hash and its predecessor's. "Verify chain" re-walks all 70k+ entries server-side.

Approval queue - humans keep the final call

certacito.ai > Approval Queue

2 new Critical-risk items escalated in the last 5 minutes

CERTACITO.AI / ACTIVITY / APPROVAL QUEUE

Approval Queue

Human reviewer action required for High and Critical risk escalations

AGT-health-018 APR-F8E1A18C MEDIUM	58:41
{'path': '/data/reports/export_2938.csv', 'count': 847}	until auto-reject
RULE-003	<button>Deny</button> <button>Approve</button>
AGT-analytics-007 APR-11B6EB90 MEDIUM	58:09
{'path': '/data/reports/export_2829.csv', 'count': 847}	until auto-reject
RULE-003	<button>Deny</button> <button>Approve</button>
AGT-gp-office-001 APR-71FAC055 HIGH	57:43
Agent attempts to email referral to external address (ESCALATED for approval)	until auto-reject
RULE-006	<button>Deny</button> <button>Approve</button>
AGT-gp-office-001 APR-D6099CF0 HIGH	12:51
Agent attempts to email referral to external address (ESCALATED for approval)	until auto-reject
RULE-006	<button>Deny</button> <button>Approve</button>

High/Critical escalations pause here with a live SLA countdown. Expiry auto-rejects (fail-closed); every decision is attributed to the signed-in reviewer.

Policy rules - governance as config

The screenshot displays the 'Policy Rules' management interface in the CERTACITO.AI dashboard. The left sidebar contains navigation links for MAIN (Agent Overview, Dashboard, Activity, Audit log, Approval queue) and GOVERNANCE (Policy rules, Agent registry). The main content area shows a list of policy rules, each with a unique ID, name, action type, risk threshold, default outcome, regulatory tag, status, and last modified date. A '+ Create new rule' button is visible in the top right of the main area.

Policy Rules
Manage enforcement rules for AI agent governance

Rules are stored as **version-controlled config files**, not model prompts. All changes are tracked with git-style versioning.

Filters: All, data_access, external_call, file_write, prompt_content, tool_invoke, email_send, credential_access, db_read

Rule ID	Name	Action type	Risk threshold	Default outcome	Regulatory tag	Status	Last modified
LIB-HEALTH-001	Patient record access req...	data_access	CRITICAL	DENY	Privacy Act 1988 s13G	Active	2026-06-25 v1
RULE-001	Out-of-scope data access...	data_access	CRITICAL	DENY	Privacy Act 1988	Active	2026-06-25 v3
RULE-002	Unsanctioned external cal...	external_call	HIGH	DENY	ISO 27001	Active	2026-06-25 v2
RULE-003	High-volume file write esc...	file_write	MEDIUM	ESCALATE	SOC 2 Type II	Active	2026-06-25 v4
RULE-004	Prompt injection detection	prompt_content	CRITICAL	DENY	OWASP LLM Top 10	Active	2026-06-25 v5
RULE-005	Approved tool invocation ...	tool_invoke	LOW	PERMIT	Internal Policy	Active	2026-06-25 v1
RULE-					ASD Essential		2026-06-25

Create, edit, version and toggle rules; changes apply to the very next intercepted action. Each rule carries its regulatory alignment tag.

Live demo - the full loop in 3 minutes

1. Sign in → live dashboard, decisions streaming in real time
2. Healthcare scenario: agent tries an out-of-scope Medicare record read → **DENY**, visible within a second
3. Bulk export attempt → **ESCALATE** → approve it in the queue as the human reviewer
4. Audit log: open the decision record, masked payload, then **Verify chain** across 70k+ entries
5. Flip the policy rule off → same action now permits - governance is config
6. Ask the agent to skip the gate entirely → it cannot; the action never reaches a shell

Step 6 is the one to watch. Governance the agent can opt out of is not governance - so the agent is only permitted to execute through the gate, and an ungoverned command is refused before it runs.

Fallback: full recording of this sequence in case the live system misbehaves on the day.

Testing found our best war story

- **44 automated tests** - unit (policy, audit, risk, guardrails) + live integration + RBAC regression.
- **CI on every push** - GitHub Actions runs the suite against a fresh PostgreSQL and builds the frontend.
- **Fail-closed verified** - tests cover engine error, unknown action, missing key, unreachable API.

War story 2: what a clean deploy found

Deploying to a machine that had never seen our code broke four things a passing test suite had hidden: an unpinned bcrypt that 500'd every login, a first-account bug that made the bootstrap admin a Viewer, and paths hardcoded to one developer's home directory.

Every one of them was invisible on the box we built it on. **Nothing was actually reproducible until we tried to reproduce it.**

War story 1: the forked audit chain

Our chain-verification test started failing. Root cause: two *concurrent* intercepts could both read the same chain head and both append to it - forking the "immutable" chain. A race no amount of mock data would ever have shown.

Fix: appends are now serialised behind a lock. **Repair:** a tool that first proves it can reproduce the stored hashes byte-for-byte, then re-links the forks (16,722 entries).

This is exactly why the audit log has an integrity check at all: it caught us, before it has to catch an attacker.

Live on Azure, agent and all

Running now (what you'll see demoed)

- Azure VM: API + built frontend in one image, PostgreSQL and Redis alongside
- The governed agent runs **on the same VM** - nothing depends on a team member's machine
- GitHub repo with Actions CI green on every push
- One-command marker setup: `docker compose up`

Why it moved off the staging box

- The team needed access without anyone handing out server logins
- Access control is the product's own RBAC, not SSH keys
- Secrets are env-var based, so the Key Vault swap stays config, not code

The architecture was containerised from sprint 1 specifically so this move was an infrastructure task, not a rebuild - it took a day.

Where we are, what's left

Against the original plan

Every Must-have is implemented and demonstrable, including the Azure host - ahead of the plan's "core loop by A4" target. Should-haves FR-08/09/10 are done; FR-11 is externally blocked.

Risks we're managing

- Group 2 contract slip → healthcare demo stands in (agreed fallback)
- Live demo depends on the agent's model provider → recorded walkthrough as fallback

Remaining to final delivery	Owner
Custom domain + TLS + CI deploy stage on Azure	Nico
Group 2 integration once their API lands	Peter
Condition-expression parser (lift FR-02 limitation)	Daniel
Background SLA worker (lift FR-05 limitation)	Daniel / Peter
Exhibition walkthrough + fallback recording	Allan / Roland
Accessibility + usability pass with sponsor	Sai

A governance loop you can watch working

An agent action is proposed, intercepted, evaluated against policy, escalated to a human when it matters, and recorded in a chain that proves nobody rewrote history. That is the system we set out to build in A2, designed in A3, and are demonstrating today - live, tested, and documented.

Appendix documents: architecture · RTM · functionality & interaction · interface changes · brand guide · contribution table
Code: zipped repo + README quick start (docker compose up) for markers

Questions - and sponsor/supervisor sign-off.